Laboratorio SUIDX: Writeup

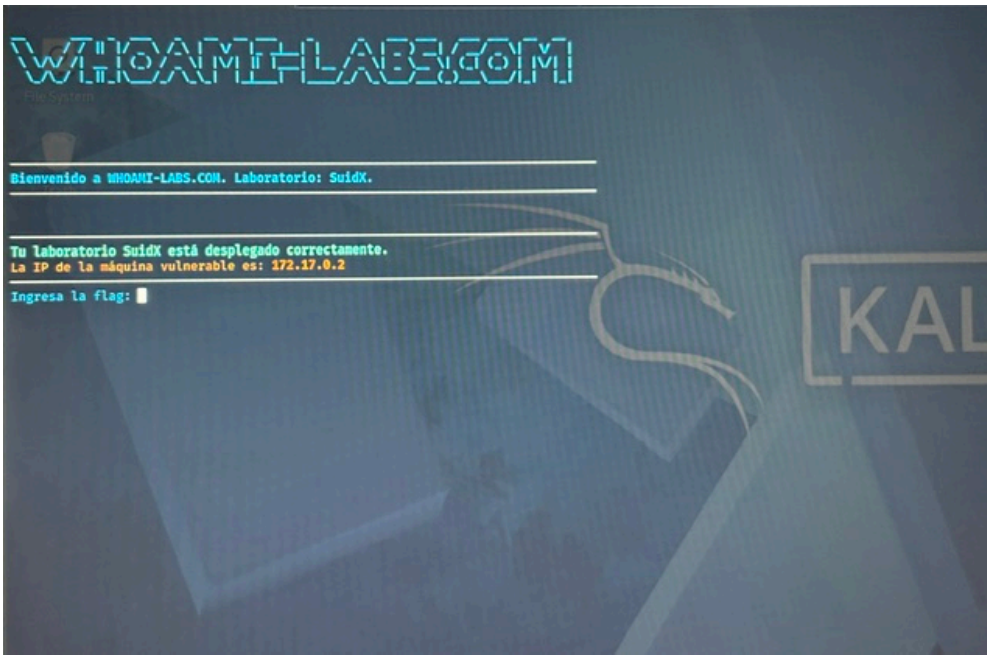
Conoce cómo dominar las técnicas de escalada de privilegios

Writeup: SUIDX - WHOAMI-LABS

Laboratorio de escalada de privilegios Linux (SUID) -whoami-labs

Levantamos el laboratorio con el siguiente comando:

sudo bash startlab.sh suidx.tar



Resumen

Laboratorio de pentesting enfocado en explotación de binarios SUID mal configurados. Máquina objetivo desplegada en 172.17.0.2, accesible desde Kali Linux dentro de la red del laboratorio.

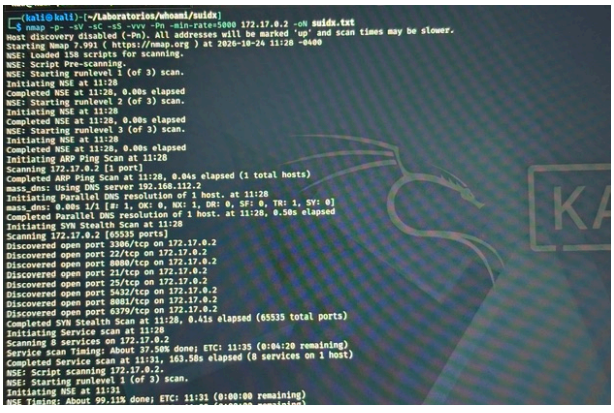
1.Reconocimiento con Nmap

Se realizó un reconomiento inicial para identificar que servicios, scripts y versiones están activos por defecto.

nmap -p- -sV -sC -sS -vvv -Pn --min-rate=5000 172.17.0.2 -oN suidx.txt

Explicación de parámetros

- **-p-** : Escaneo de los 65535 puertos TCP
- **-sV** : Deteción de versiones.
- **-sC** : Scripts básicos NSE
- **-sS** : SYN Scan.
- **-vvv :** very verbose muestra la información detallada durante el proceso
- **-Pn :** Omitir el descubrimiento inicial del host.
- **--min-rate=5000:** Aumenta la velocidad del escaneo.
- **-oN nmap.txt** : Guarda la salida.





Puertos y Servicios detectados

Puertos	Servicios	Detalle
21/tcp	**ftp?**	**sin banner**
22/tcp	**ssh**	**OpenSSH 8.9p1 Ubuntu**
25/tcp	**smtp?**	**sin conexión establecida**
3306/tcp	**mysql?**	**sin banner**
5432/tcp	**postgrespl?**	**sin banner**
6379/tcp	**redis?**	**sin banner**
8080/tcp	**http**	**Apache httpd 2.4.52 (Ubutun)-título “suidx Lab|whoami-labs”**
8081/tcp	**blackic-icecap?**	**sin banner**

El puerto 8080 (HTTP) se identifica como el punto de entrada principal.

2.Enumeración (Feroxbuster)

feroxbuster -u http://172.17.0.2:8080 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,txt,bak,sql,backup,zip,tar

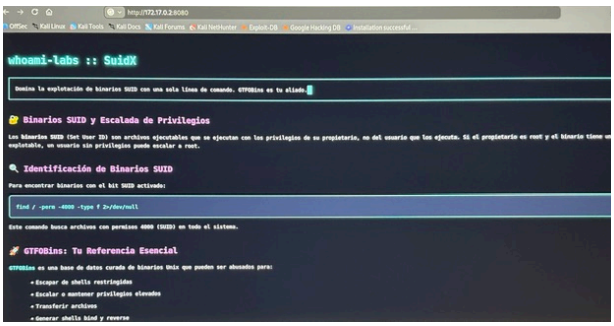
Explicación de los parametros:

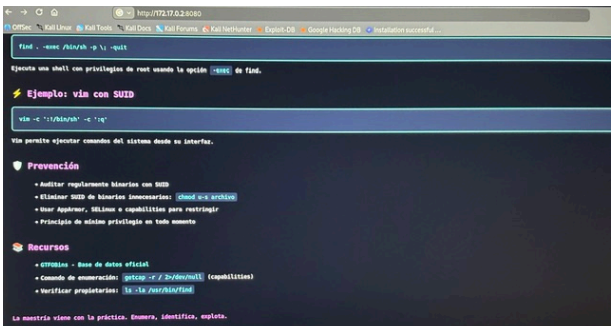
- **-u:** URL objetivo donde se prueban rutas
- **-w:** wordlist de nombres de directorios/archivos a probar
- **-x:** extenciones que se añaden a cada palabra del wordlists

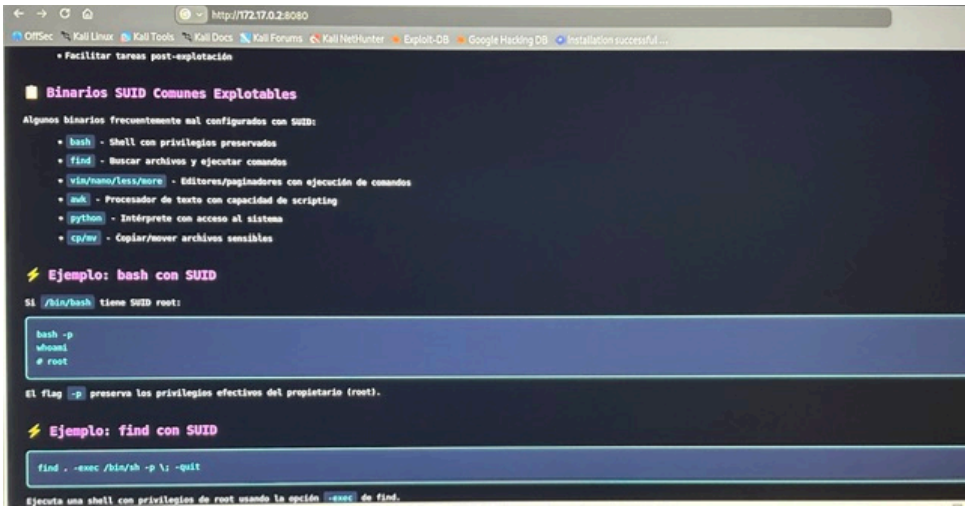


Se descubre el directorio /user/ (código 301 - redicción a /user/index/html, código 200).

La página principal del puerto 8080 contiene una guía educativa sobre explotación de binarios **SUID y GTFOBins.**

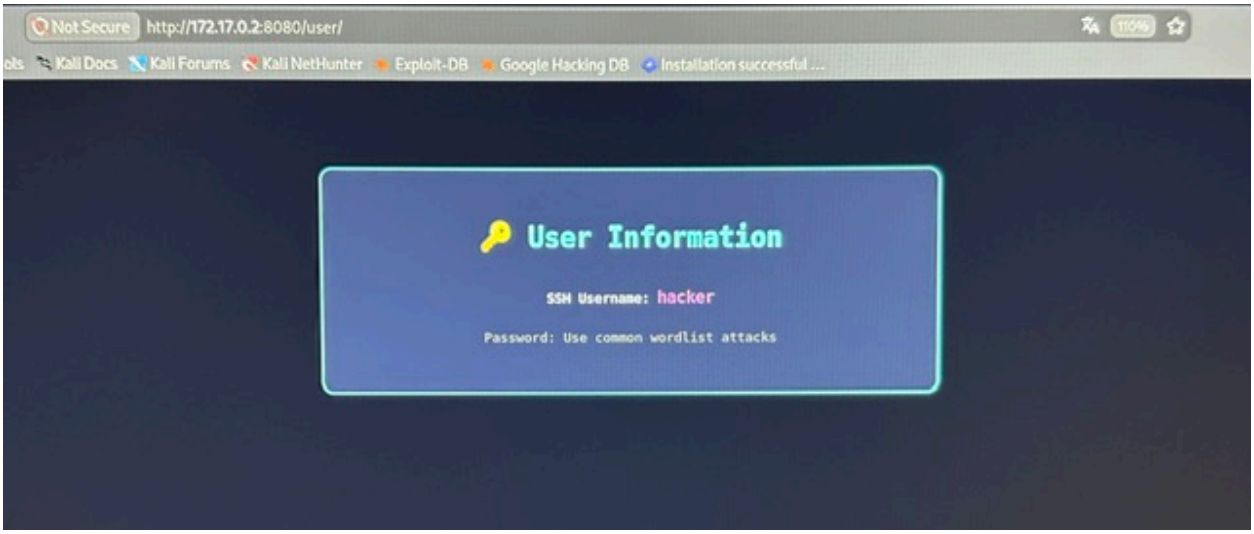






Al visitar /user/ se revelan credenciales parciales:

- **SSH username: hacker**
- **Password: “use common worlist attacks (pista para ataque de diccionario)**



3.Fuerza bruta de credenciales SSH

Se ejecutó fuerza bruta con hydra para identificar el password

hydra -l hacker -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.2

Explicacion de los parametros:

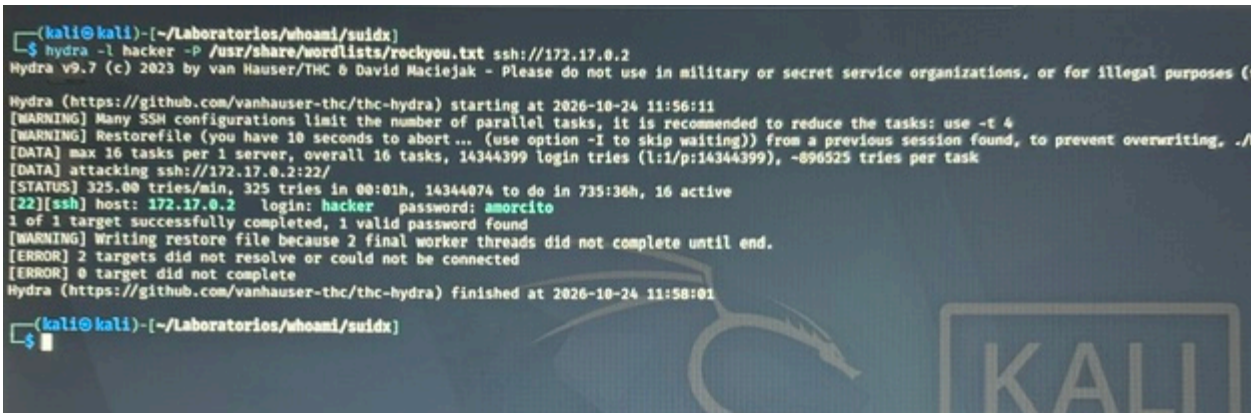
-l hacker: especifica un único usuario fijo contra el que se va a probar

-P: indica una lista de contraseñas a probar, una por línea

rockyou.txt: es un diccionario filtrado de contraseñas

Teniendo como resultado

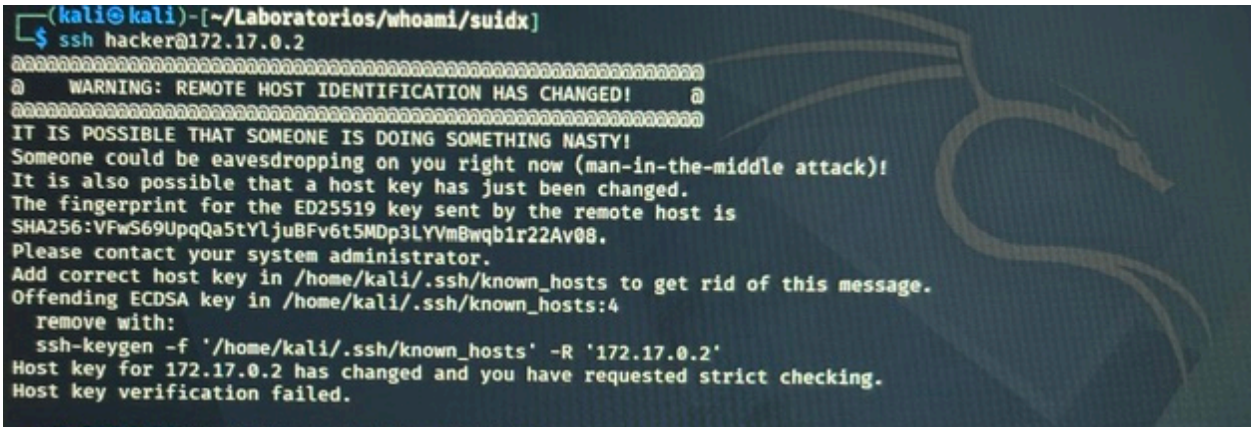
- **[22][ssh] host: 172.17.0.2**
- **login: hacker**
- **password: amorcito**



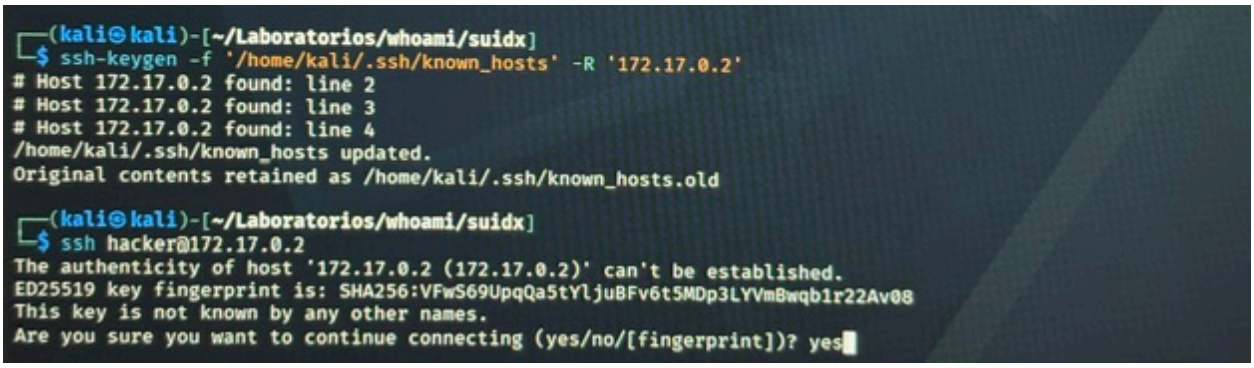
4.Acceso por SSH

ssh hacker@172.17.0.2

Al cambiar la máquina de IP/clave de host respecto a conexiones previas, aparece la advertencia de “REMOTE HOST IDENTIFICATION HAS CHANGED”. Se limpia la entrada antigua y se reconecta:

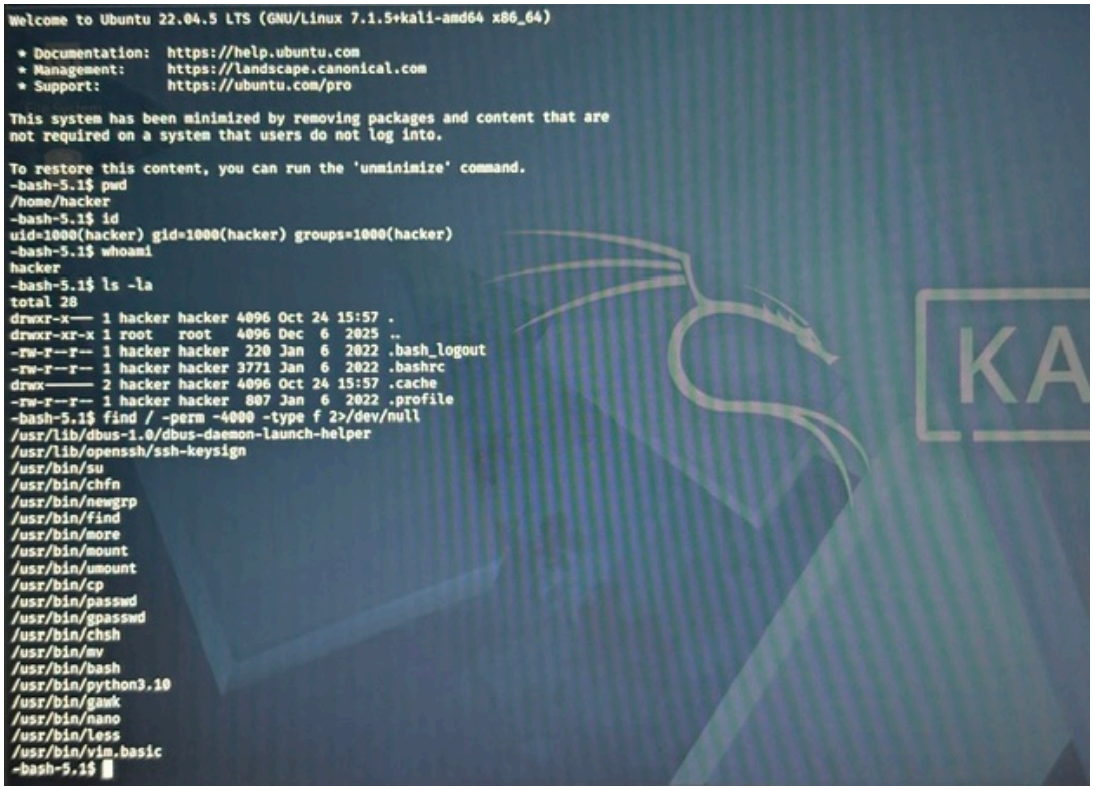


Se acepta la nueva huella (yes) y se autentica con contraseña amorcito.



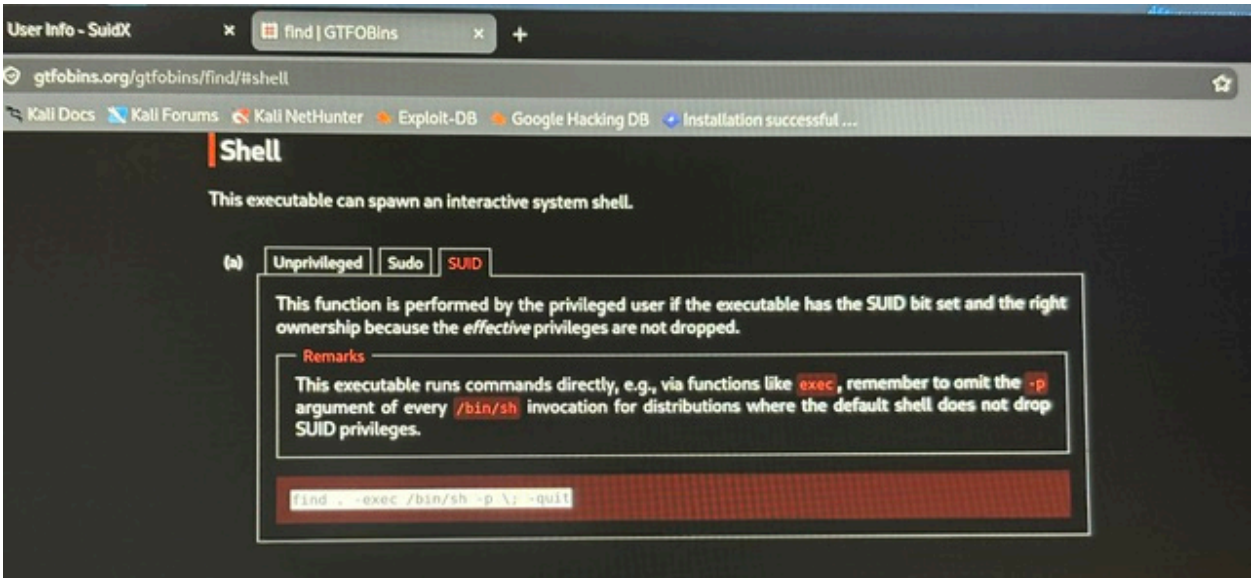
5.Enumeración local y escalada de privilegios

Ya dentro como usuario hacker

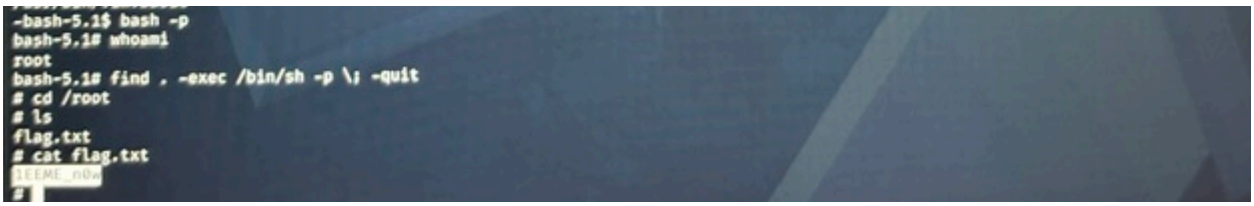


Entre los binarios SUID listados aparece /usr/bin/find, que no debería tener el bit SUID activo por defecto.

Consultando GTFOBins para find, en la sección Shell.

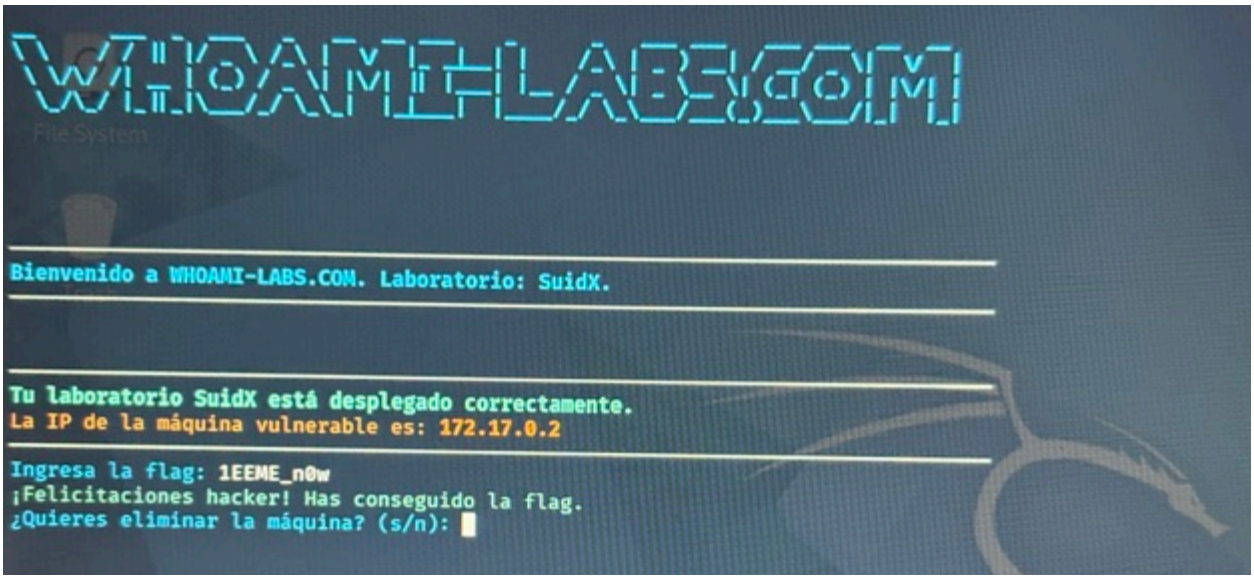


Explotación



6.Flag obtenida

Se introduce la flag en la interfaz de whoami-labs y se confirma



Lecciones aprendidas

- Un escaneo completo de puertos con nmap es clave para no pasar por alto servicios secundarios (FTP,Redis,PostgreSQL,etc.), aunque en este caso el vector fue el servicio web.
- La fuerza bruta de direcciones (feroxbuster) permite descubrir rutas ocultas que filtran información sensible, como credenciales parciales.
- rockyou.txt sigue siendo efectivo contra contraseñas débiles o predecibles.
- find con bit SUID es una de las vías de escalada más directas y documentadas (GTFOBins).